BOUMDJEL CYRILLE

MAT : CM-UGA-24FS0788

FILIERE : SISD

UE : SIS589

TP CHAP : 3 & 4

Ex. 3.1 — Écriture de règle Suricata

```
alerttcp 192.168.20.0/24 any ->any ![80,443,22] (

msg:"REVERSE_SHELLNetcatnc -e /bin/bash depuis VLAN20";
flow:established,to_server;
    content:"nc"; nocase;
    content:"/bin/bash"; nocase; distance:0;
classtype:trojan-activity;
metadata:mitre_technique T1059.004,

mitre_tacticexecution;
    sid:9000001;
    rev:1;

)
```

Ex. 3.2 — Analyse d'alerte EVE-JSON

Contexte : À partir d'une alerte EVE-JSON générée par Suricata sur un trafic contenant nc -e /bin/bash, on répond aux 4 questions de qualification.

(a) Attaque probable

Reverse shell via Netcat. L'attaquant exécute nc -e /bin/bash sur la machine victime pour lui faire initier une connexion sortante vers son serveur C2. Cette technique permet de contourner les pare-feux qui bloquent les connexions entrantes.

(b) TTP MITRE ATT&CK

T1059.004 — Command & Scripting Interpreter : Unix Shell (Tactic : Execution - TA0002)

(c) Trafic bloqué ou alerté ?

Réponse : Avec l'action alert, le trafic est uniquement alerté — il n'est PAS bloqué. Suricata est en mode NIDS (passif/TAP). Pour bloquer activement, il faudrait :

- Utiliserl'action drop (mode IPS inline)
- Déployer Suricata en mode inline (bridge ouNFQueue sous Linux)

(d) 3 étapes de qualification N1

1. Vérifier la légitimité : Confirmer que l'IP source (VLAN 20) ne correspond pas à un outil d'administration autorisé (test de pénétration interne, scanner de vulnérabilités). Consulter la CMDB(configuration management and data base) et les tickets ouverts.

2. Corréler dans le SIEM : Rechercher d'autres alertes associées à la même IP source/destination : connexions sortantes inhabituelles, tentatives d'escalade de privilèges (T1068), mouvement latéral (T1021). Vérifier les logs système (HIDS).

3. Escalader en N2 si confirmé : Isoler la machine compromise du réseau (quarantaine VLAN), collecter les artefacts (capture pcap, logs Suricata EVE-JSON, mémoire vive si possible), ouvrir un ticket d'incident P1 et notifier le SOC N2.

Ex. 3.3 — Plan de déploiement IDS pour LiZbiZ-SIS

Localisation et configuration des capteurs

Emplacement	Type	Mode	Rôle
Cœur de réseau (agrégation)	NIDS (Suricata)	TAP (passif)	Visibilité globale inter-VLAN, détection sans impact réseau
DMZ (serveurs exposés)	NIDS (Suricata)	Inline / IPS	Blocage actif des attaques entrantes (action drop)
VLAN 20 (utilisateurs)	NIDS (Suricata)	TAP (passif)	Détection mouvements latéraux et reverse shells
Serveurs critiques (SIS)	HIDS (Wazuh)	Agent local	Intégrité fichiers (FIM), logs système, rootkit detection
Postes sensibles / admins	EDR	Agent local	Comportement processus, mémoire, lateralmovement
Frontière Internet / pare-feu	NIDS (Suricata)	Inline / IPS	Filtrage périmétrique, blocage C2 et scans entrants

Ex. 4.1 — Qualification juridique.

Dans ce scénario, un employé outrepasse ses droits pour exporter des données massives. Selon la Loi 2010/012 relative à la cybersécurité et la cybercriminalité au Cameroun :

- Infractions potentielles :
  - Accès illégitime : Accès à tout ou partie d'un système informatique sans droit (atteinte à la confidentialité).
  - Atteinte à l'intégrité des données : L'extraction non autorisée de 50 000 dossiers peut être qualifiée de vol de données numériques ou détournement de fichiers.
- Preuves à collecter :
  - Logs d'accès au SGBD : Pour prouver l'heure, l'identifiant utilisé et la requête d'exportation.
  - Logs réseaux (SIEM) : Pour tracer le transfert des données vers un support externe ou un Cloud.
  - Éléments physiques : Clés USB ou historique de navigation sur le poste de l'employé.
- Délai de notification à l'ANTIC : La loi impose généralement une notification immédiate ou dans un délai de 72 heures maximum après la découverte d'un incident grave touchant des données sensibles.

Ex. 4.2 — Chaîne de custody

PV DE SAISIE COMPLET :

- **Contexte :** suspection
- **Pièce :**laptop dell
- **Date et heure de collecte :** 02/05/2026, 16 :50AM
- **Collecteur :** BOUMDJEL CYRILLE
- **Méthode :** confiscation du laptop

- **Conservation du laptop :** Coffre-fort scellé dans salle serveur

Ex. 4.3 — Politique de rétention

Référentiels Applicables par Juridiction

Juridiction	Rôle	Textes Applicables
Cameroun	Siège social / Droit principal	Loi n°2010/012 sur la cybersécurité et la protection des données ; Directives ANTIC
Nigeria	Juridiction client	NDPR 2019 (Nigeria Data Protection Regulation) ; Nigeria Data Protection Act 2023 ; NITDA
Côte d'Ivoire	Juridiction client	Loi n°2013-450 sur la protection des données personnelles ; ARTCI

Politique de Rétention Unifiée

Catégorie de Données	Durée de Rétention	Base Légale
Données clients actifs (contrats)	Durée du contrat + 5 ans	Droit commercial camerounais + NDPR
Données clients inactifs / prospects	1 an après dernier contact	Standard le plus restrictif (Loi 2013-450)
Logs de sécurité et d'accès	5 ans minimum	Exigences ANTIC + NITDA
Données financières et comptables	10 ans	Obligations fiscales communes aux 3 pays
Données RH internes	10 ans après fin de contrat	Code du travail camerounais
Données sensibles (biométrie, santé)	Durée strictement nécessaire + suppression certifiée	Toutes juridictions